DEPI Software Testing - Final Project

Risk Assessment & Mitigation Plan

Banking Transaction System

> **How to read this document**
> **Sections 2 to 4** explain the method: who manages risks, how a risk is scored, and which responses exist.
> **Section 5** is the summary: counts, heat maps and the top 10 risks.
> **Sections 6 and 7** hold the full register and one detailed card per risk (description, cause, consequence, warning signs, mitigation, contingency, owner, residual risk).
> **Sections 8 and 9** give the Plan B scenarios, the descoping order and how risks are monitored and escalated.

Contents

- 1. Purpose and scope
- 2. Risk management approach
- 3. Scoring method
- 4. Risk response strategies
- 5. Risk summary
- 6. Risk register
- 7. Detailed risk cards
- 8. Contingency plans and descoping order
- 9. Monitoring, control and escalation
- 10. Assumptions, dependencies and constraints
- 11. Risk review log and approval
- Appendix A. Glossary

1. Purpose and Scope

This plan identifies what could go wrong in the Banking Transaction System project, measures how serious each risk is, decides what the team does to prevent it, and defines what the team does if it happens anyway. It also says who watches each risk and how often.

Scope. The plan covers the full project life cycle: planning, development, testing, security, documentation and the final presentation, for the core banking system.

Why it matters for this project. The team is small, most members are learning several new tools at once, the time is about 8 weeks, and the system handles money rules where a small mistake is visible. A written risk plan lets the team decide early instead of reacting late.

2. Risk Management Approach

2.1 Process

#	Step	What the team does	Output
1	Identify	Risks are collected from the requirements review, the design, the first build and the weekly meeting. Anyone can raise a risk.	New entry in the register
2	Analyse	The owner scores likelihood and impact using the scales in Section 3.	Score and rating
3	Evaluate	Risks are ranked. The rating decides how much attention and what response is needed.	Priority list
4	Respond	The owner chooses a response (avoid, mitigate, transfer, accept), writes the actions, and sets the warning signs and the contingency plan.	Mitigation and contingency plan
5	Monitor	Weekly review in the team meeting. Scores, status and warning signs are updated.	Updated register and log
6	Close	A risk is closed when it can no longer happen or its residual rating stays Low for three reviews.	Closed risk

2.2 Roles and responsibilities

Role	Responsibility
Risk Coordinator (QA Lead)	Keeps the register up to date, prepares and chairs the weekly risk review, checks that every risk has an owner and a date, reports the status.
Risk Owner	Named person for each risk. Carries out and tracks the mitigation actions, watches the warning signs, activates the contingency plan, and updates the score.
The team	Approves responses for High and Critical risks, decides on Plan B scenarios, and informs the instructor when needed. A member is named to escalate once roles are assigned.
Whole team	Reports new risks and warning signs immediately, follows the agreed actions.
Instructor	Informed about Critical risks and about any risk that threatens a named deliverable or the schedule.

3. Scoring Method

Each risk gets a likelihood score and an impact score from 1 to 5. The risk score is likelihood multiplied by impact (1 to 25).

3.1 Likelihood scale

Score	Level	Probability	Meaning in this project
1	Rare	Below 10%	Would need an unusual event.
2	Unlikely	10% to 30%	Could happen, but there is no sign of it.
3	Possible	30% to 50%	Has happened in similar student projects.
4	Likely	50% to 80%	Expected unless the team acts.
5	Almost certain	Above 80%	Will happen.

3.2 Impact scale

Score	Level	Meaning in this project
1	Negligible	No effect on the schedule or the result.
2	Minor	Up to one day of delay, or a cosmetic problem.
3	Moderate	About a week of delay, or a Should feature is lost, or testing evidence is weaker.
4	Major	A Must feature is lost or unstable, a named deliverable is missing, or a clear security or money-integrity defect remains.
5	Severe	The project cannot be demonstrated, or the system cannot be trusted at all.

3.3 Rating bands and required response

Rating	Score	Required response
Critical	17 to 25	Act immediately. Escalate the same day to the team. Discuss with the instructor if a deliverable is threatened. No new feature work on the affected area until a response is agreed.
High	10 to 16	Mitigation actions with a named owner and a date. Reviewed every week. The team approves the response.
Medium	5 to 9	Mitigation actions where cheap. Reviewed every week. Owner watches the warning signs.
Low	1 to 4	Accept and monitor. Reviewed at milestones (end of weeks 1, 4, 6 and 8).

Inherent score is the score before the mitigation actions. **Residual score** is the expected score after the mitigation actions are in place. Both are recorded for every risk.

4. Risk Response Strategies

Strategy	Meaning	Example in this project
Avoid	Change the plan so the risk cannot happen.	Do not expose the application to the internet (a local demo avoids many security and hosting risks).

Strategy	Meaning	Example in this project
Mitigate	Reduce the likelihood or the impact.	Store money as whole piasters and add a parallel-withdrawal test to reduce money-integrity risk.
Transfer	Move the impact to someone else.	Use a library or framework for security (Spring Security, BCrypt) instead of writing our own.
Accept	Do nothing now, but monitor.	Accept that Spring Boot 3.5 gets no free updates, for a local demo, and state it in the final report.

5. Risk Summary

5.1 Number of risks by rating

	Critical	High	Medium	Low
Inherent (before mitigation)	0	13	9	2
Residual (after mitigation)	0	0	13	11

The register contains 24 risks. Before mitigation there are 13 High and 9 Medium risks and no Critical risk. If the mitigation actions are carried out, none remains High.

5.2 Heat map before mitigation (inherent)

Likelihood \ Impact	1 Negligible	2 Minor	3 Moderate	4 Major	5 Severe
5 Almost certain					
4 Likely			R-07, R-08, R-15, R-21	R-01, R-02, R-17	
3 Possible		R-10	R-04, R-09, R-12, R-16, R-18	R-06, R-11, R-20, R-24	R-03, R-19
2 Unlikely		R-22, R-23		R-05, R-13, R-14	
1 Rare					

5.3 Heat map after mitigation (residual)

Likelihood \ Impact	1 Negligible	2 Minor	3 Moderate	4 Major	5 Severe
5 Almost certain					
4 Likely					
3 Possible		R-21	R-01, R-02, R-17		

Likelihood \ Impact	1 Negligible	2 Minor	3 Moderate	4 Major	5 Severe
2 Unlikely		R-09, R-10, R-12, R-15, R-18	R-04, R-07, R-08, R-11, R-16, R-19, R-24	R-03, R-06	
1 Rare		R-22, R-23	R-13, R-14, R-20	R-05	

5.4 Top 10 risks (by inherent score)

ID	Risk	Score	Rating	Owner	Residual
R-01	Scope too large for the available time	16	High	Tech Lead	9 (Medium)
R-02	Skill gap inside the team	16	High	Tech Lead	9 (Medium)
R-17	Limited availability (exams, other courses and training)	16	High	Whole team	9 (Medium)
R-03	Dependence on one or two members for reviews and critical knowledge	15	High	Tech Lead	8 (Medium)
R-19	Demo failure on presentation day	15	High	Tech Lead	6 (Medium)
R-06	Money-integrity or concurrency bugs	12	High	Tech Lead	8 (Medium)
R-07	Ambiguous or changing requirements	12	High	QA Lead	6 (Medium)
R-08	Flaky or fragile UI automation (Selenium)	12	High	QA Lead	6 (Medium)
R-11	Security weaknesses in the application	12	High	Tech Lead	6 (Medium)
R-15	Merge conflicts and a broken main branch	12	High	Tech Lead	4 (Low)

6. Risk Register

Compact view of all risks. Section 7 has the full detail for each one. L = likelihood, I = impact.

ID	Category	Risk	L	I	Score	Rating	Owner	Residual
R-01	Schedule & Scope	Scope too large for the available time	4	4	16	High	Tech Lead	9 Medium
R-02	People & Skills	Skill gap inside the team	4	4	16	High	Tech Lead	9 Medium
R-03	People & Skills	Dependence on one or two members for reviews and critical knowledge	3	5	15	High	Tech Lead	8 Medium
R-04	Technical	Framework learning curve (Spring Boot and JPA)	3	3	9	Medium	Tech Lead	6 Medium
R-05	Technical	SQLite limitations (no exact decimals, single writer, dialect support)	2	4	8	Medium	Tech Lead	4 Low
R-06	Technical	Money-integrity or concurrency bugs	3	4	12	High	Tech Lead	8 Medium
R-07	Requirements	Ambiguous or changing requirements	4	3	12	High	QA Lead	6 Medium
R-08	Quality & Testing	Flaky or fragile UI automation (Selenium)	4	3	12	High	QA Lead	6 Medium
R-09	Environment & Tooling	Different laptops give different results	3	3	9	Medium	QA Lead	4 Low
R-10	Security	Spring Boot 3.5 no longer receives free security updates	3	2	6	Medium	Tech Lead	4 Low

ID	Category	Risk	L	I	Score	Rating	Owner	Residual
R-11	Security	Security weaknesses in the application	3	4	12	High	Tech Lead	6 Medium
R-12	Security	Vulnerable or malicious dependencies	3	3	9	Medium	Tech Lead	4 Low
R-13	Security	Secrets or databases committed to Git	2	4	8	Medium	Tech Lead	3 Low
R-14	Environment & Tooling	Loss of work or data	2	4	8	Medium	Whole team	3 Low
R-15	Process	Merge conflicts and a broken main branch	4	3	12	High	Tech Lead	4 Low
R-16	Quality & Testing	Low code quality or low test coverage	3	3	9	Medium	QA Lead	6 Medium
R-17	People & Skills	Limited availability (exams, other courses and training)	4	4	16	High	Whole team	9 Medium
R-18	People & Skills	Unclear ownership or poor communication	3	3	9	Medium	Whole team	4 Low
R-19	Delivery	Demo failure on presentation day	3	5	15	High	Tech Lead	6 Medium
R-20	Delivery	Instructor expectations not covered (named deliverables)	3	4	12	High	QA Lead	3 Low
R-21	Schedule & Scope	Estimation errors	4	3	12	High	Tech Lead	6 Medium
R-22	Environment & Tooling	Tool access and plan limits (GitHub organisation, Jira)	2	2	4	Low	Tech Lead	2 Low
R-23	External	Market figures change (limits, fees, interest rates)	2	2	4	Low	QA Lead	2 Low
R-24	Quality & Testing	Code that the team does not fully understand	3	4	12	High	Tech Lead	6 Medium

7. Detailed Risk Cards

Each card lists the cause, the consequence, the early-warning signs, the preventive actions, the contingency plan, the owner, the residual risk and the status.

R-01 | Scope too large for the available time	
Category	Schedule & Scope
Description	The system has many modules (accounts, transactions with fees, statements, admin, jobs, security, audit) and the project has about 8 weeks. If the team tries to finish everything, many features end up half done.
Cause	Ambitious scope; five people with mixed experience; other courses compete for time.
Consequence	Must features missing or unstable at the demo; late nights; quality drops.
Likelihood x Impact	4 x 4 = 16 (High)
Early-warning indicators	Fewer than 60% of the planned Jira items finished for two weeks in a row; Must items still open at the start of week 5.
Mitigation (preventive actions)	MoSCoW priorities in the requirements (Must/Should/Could). MVP is defined as all Must items. Build vertical slices (one complete feature at a time). Weekly scope check against the plan. Agree the descoping order in advance (Section 8 of this plan).
Contingency plan (if it happens)	Apply the descoping order: drop Could items first, then Should items from the bottom of the list. The team confirms the cut in the weekly meeting and updates the requirements document version.
Risk owner	Tech Lead
Residual risk (after mitigation)	3 x 3 = 9 (Medium)
Status	Open - monitored weekly
Related requirements	All Must requirements; Spec. Section 9.1

R-02 | Skill gap inside the team	
Category	People & Skills
Description	Team members have different levels of experience, and several tools (Spring Boot, JPA, Selenium, Postman) are new to most of the team.
Cause	Mixed experience; many new tools in a short time.
Consequence	Slow progress, bugs, and a few members becoming bottlenecks.
Likelihood x Impact	4 x 4 = 16 (High)
Early-warning indicators	A task is blocked for more than 2 days; pull requests are rejected repeatedly for the same mistake; a member cannot explain their own code.
Mitigation (preventive actions)	Reference implementation already exists (deposit and withdraw slice). Small vertical tasks with a pattern to copy. Pair work on each member's first pull request. Short walkthroughs of the code base. Code review comments explain the why. Shared learning notes in the repository.
Contingency plan (if it happens)	Reassign the task to a more experienced member and keep the other member as reviewer-in-training. Reduce the task scope. The most experienced members take the critical-path items (transfer, security).
Risk owner	Tech Lead
Residual risk (after mitigation)	3 x 3 = 9 (Medium)

Status	Open - mitigation running
Related requirements	Spec. Section 9.2

R-03 | Dependence on one or two members for reviews and critical knowledge	
Category	People & Skills
Description	Architecture knowledge, critical parts of the code and the review work can end up with one or two people. If they are ill, busy or away, work stops.
Cause	Uneven experience in the team.
Consequence	Merge queue stops; critical features delayed; knowledge lost.
Likelihood x Impact	3 x 5 = 15 (High)
Early-warning indicators	Pull requests waiting for review more than 48 hours; a key member unavailable for more than 3 days.
Mitigation (preventive actions)	Document decisions in the requirements and README. A second reviewer for non-critical pull requests. Critical parts have a named backup who has read and run them. Short design notes next to complex code.
Contingency plan (if it happens)	A backup reviewer approves non-security changes. Freeze new features and focus on stabilising and testing what exists until the key member is back.
Risk owner	Tech Lead
Residual risk (after mitigation)	2 x 4 = 8 (Medium)
Status	Open - monitored weekly
Related requirements	NFR-08; Spec. Section 9.3

R-04 | Framework learning curve (Spring Boot and JPA)	
Category	Technical
Description	Spring annotations, transactions, security configuration and JPA mapping behave in ways that are hard to guess for beginners.
Cause	New framework; much behaviour is hidden behind annotations.
Consequence	Time lost debugging configuration instead of building features.
Likelihood x Impact	3 x 3 = 9 (Medium)
Early-warning indicators	More than one member stuck on configuration errors in the same week.
Mitigation (preventive actions)	An initial skeleton and a first working slice are included in the repository. README explains how to run and test. Errors are shared in the team chat with the first 40 lines of the stack trace. Follow existing patterns rather than inventing new ones.
Contingency plan (if it happens)	A more experienced member fixes the configuration and records the solution in the README troubleshooting section.
Risk owner	Tech Lead
Residual risk (after mitigation)	2 x 3 = 6 (Medium)
Status	Open
Related requirements	NFR-09, NFR-10

R-05 | SQLite limitations (no exact decimals, single writer, dialect support)	
Category	Technical
Description	SQLite stores decimals as floating point and allows one writer at a time. The Hibernate SQLite dialect is a community module.
Cause	Database choice made by the team.
Consequence	Rounding errors in money, locking errors under parallel requests, or mapping problems.
Likelihood x Impact	2 x 4 = 8 (Medium)
Early-warning indicators	Any 'database is locked' error; any balance mismatch in tests; a failing database or concurrency test.
Mitigation (preventive actions)	Money stored as whole piasters and rates as basis points. Immediate transactions, WAL mode, busy timeout, pool of one connection. A short spike in week 1 confirms the setup (exact-money round trip and the parallel-withdrawal test TC-C-01); the test stays in the suite.
Contingency plan (if it happens)	Switch to H2 or MySQL by configuration (the code uses JPA). Decision by the team; must be taken before week 4.
Risk owner	Tech Lead
Residual risk (after mitigation)	1 x 4 = 4 (Low)
Status	Open - to be confirmed by the week-1 spike
Related requirements	NFR-01, TXN-05, TXN-06; Spec. Section 7.8

R-06 | Money-integrity or concurrency bugs	
Category	Technical
Description	Transfers, fees and limits involve several steps. A mistake can create or destroy money, bypass a limit, or leave a half-finished transfer.
Cause	Complex rules (fee, daily/monthly limits, account-type rules); parallel requests.
Consequence	Wrong balances; loss of trust in the system; failed acceptance tests.
Likelihood x Impact	3 x 4 = 12 (High)
Early-warning indicators	Ledger and balance disagree in any test; a transfer test fails intermittently; a reviewer finds logic in a controller.
Mitigation (preventive actions)	All money operations run in one database transaction. Business exceptions are unchecked so Spring rolls back. Rules live in the domain and service layers. Ledger rows are append-only. Unit, integration and concurrency tests for every rule. Every money-related pull request is reviewed by an experienced member chosen by the team.
Contingency plan (if it happens)	Stop merging new money features, reproduce the failure with a test, fix, and re-run the whole suite. If needed, disable the faulty operation behind a configuration flag for the demo.
Risk owner	Tech Lead
Residual risk (after mitigation)	2 x 4 = 8 (Medium)
Status	Open
Related requirements	TXN-03 to TXN-06; BR-26 to BR-29; Spec. Section 7.8

R-07 | Ambiguous or changing requirements	
Category	Requirements
Description	Some rules are unclear or contradict each other (for example the expected error code in test TC-F-07), and the instructor may change expectations.
Cause	Rules written before implementation; external stakeholder.
Consequence	Rework; tests that disagree with code; arguments late in the project.
Likelihood x Impact	4 x 3 = 12 (High)
Early-warning indicators	A tester and a developer disagree about expected behaviour; the instructor asks for a change.
Mitigation (preventive actions)	Static testing of the requirements document in week 1 to 2 (every ambiguity becomes a Jira ticket). Decision log in Spec. Section 10. Change control: a change needs an ID, an owner and an updated document version. Confirm open questions with the instructor early.
Contingency plan (if it happens)	Freeze the interpretation in the decision log, update the requirement and the affected test cases, and notify the team.
Risk owner	QA Lead
Residual risk (after mitigation)	2 x 3 = 6 (Medium)
Status	Open - TC-F-07 pending decision
Related requirements	Spec. Sections 8.1 and 10

R-08 | Flaky or fragile UI automation (Selenium)	
Category	Quality & Testing
Description	UI tests break when the page structure or ids change, or when they run before the page is ready.
Cause	Pages still changing; timing issues; shared test data.
Consequence	Unreliable results; time wasted on test maintenance.
Likelihood x Impact	4 x 3 = 12 (High)
Early-warning indicators	The same test fails and passes on re-run; tests broken after a UI change.
Mitigation (preventive actions)	Stable element ids (Spec. Section 7.6). Page Object Model. Explicit waits, never fixed sleeps. Pages and ids frozen at the end of week 4. Fixed seed data and a database reset before every run.
Contingency plan (if it happens)	Quarantine the flaky test, log a Jira defect, and keep the stable core flows running. Re-enable after the fix.
Risk owner	QA Lead
Residual risk (after mitigation)	2 x 3 = 6 (Medium)
Status	Open
Related requirements	NFR-05; Spec. Section 8.2

R-09 | Different laptops give different results	
Category	Environment & Tooling

Description	Team members use different operating systems, JDK versions and shells (for example PowerShell treats some Maven options differently).
Cause	No shared environment.
Consequence	'Works on my machine' problems and lost time.
Likelihood x Impact	3 x 3 = 9 (Medium)
Early-warning indicators	A member cannot run the project after a fresh clone.
Mitigation (preventive actions)	README with exact commands (including the PowerShell form). JDK 17 or higher. Embedded database, no external service. Seed data in the dev profile. First-run checklist: run the tests, then start the app.
Contingency plan (if it happens)	Pair with a more experienced member (remotely if needed) and fix the setup; add the solution to the README.
Risk owner	QA Lead
Residual risk (after mitigation)	2 x 2 = 4 (Low)
Status	Open
Related requirements	NFR-09

R-10 | Spring Boot 3.5 no longer receives free security updates	
Category	Security
Description	The 3.x line reached the end of free updates in June 2026. Known vulnerabilities found later will not be patched for free.
Cause	Choice of the last 3.x release for stability and available documentation.
Consequence	Possible vulnerable dependencies; a point to defend in the final report.
Likelihood x Impact	3 x 2 = 6 (Medium)
Early-warning indicators	Dependency check reports a High or Critical vulnerability in Spring components.
Mitigation (preventive actions)	Local demo only (not exposed to the internet). Run a dependency vulnerability check (SEC-10) before the demo. State the limitation and the upgrade path (Spring Boot 4.1) in the final report.
Contingency plan (if it happens)	If a serious issue appears and time allows, upgrade to the supported line; otherwise document it as a known limitation.
Risk owner	Tech Lead
Residual risk (after mitigation)	2 x 2 = 4 (Low)
Status	Open - accepted for a local demo
Related requirements	SEC-10; Spec. Section 9.4

R-11 | Security weaknesses in the application	
Category	Security
Description	Broken access control (IDOR), weak authentication, injection, XSS or CSRF could exist in a banking application.
Cause	Many endpoints and pages; beginners writing new code.
Consequence	Customers could see or change other customers' data; poor result in security tests.

Likelihood x Impact	3 x 4 = 12 (High)
Early-warning indicators	Any failing security test (TC-S-01 to TC-S-04); a reviewer finds a missing ownership check.
Mitigation (preventive actions)	Security requirements SEC-01 to SEC-11. Ownership check in one place (AccountService.getOwned). Deny by default. BCrypt, CSRF tokens, escaped output. Automated API security tests exist. Security cases in the manual test plan.
Contingency plan (if it happens)	Treat as a Critical defect: fix before any new feature, add a regression test, and re-run all security tests.
Risk owner	Tech Lead
Residual risk (after mitigation)	2 x 3 = 6 (Medium)
Status	Open - tests exist
Related requirements	Spec. Section 6; AUTH-03, AUTH-04

R-12 | Vulnerable or malicious dependencies

Category	Security
Description	Third-party libraries may contain known vulnerabilities or be replaced by malicious versions.
Cause	Many libraries pulled automatically by Maven.
Consequence	Security issues; supply-chain risk.
Likelihood x Impact	3 x 3 = 9 (Medium)
Early-warning indicators	Vulnerability alert from the scanner or from GitHub.
Mitigation (preventive actions)	Use released, pinned versions. Run OWASP Dependency-Check or enable Dependabot alerts once the repository exists. Review any new dependency in the pull request.
Contingency plan (if it happens)	Upgrade or replace the affected library; if impossible, document and accept the risk for the demo.
Risk owner	Tech Lead
Residual risk (after mitigation)	2 x 2 = 4 (Low)
Status	Open
Related requirements	SEC-10

R-13 | Secrets or databases committed to Git

Category	Security
Description	Passwords, keys, the SQLite file, or personal data could be pushed to the public or shared repository by mistake.
Cause	Beginners, quick commits, local files.
Consequence	Leaked credentials; exposed data; cleaning Git history.
Likelihood x Impact	2 x 4 = 8 (Medium)
Early-warning indicators	A secret scanner alert; a pull request that adds .db, .env or credentials.

Mitigation (preventive actions)	.gitignore excludes databases and .env. Credentials come from environment variables. Demo credentials exist only in the dev profile and are fictional. Enable GitHub secret scanning and push protection if available. Review file lists in every pull request.
Contingency plan (if it happens)	Rotate the exposed secret immediately, remove it from the history, and tell the team.
Risk owner	Tech Lead
Residual risk (after mitigation)	1 x 3 = 3 (Low)
Status	Open
Related requirements	SEC-08; AUTH-08

R-14 | Loss of work or data

Category	Environment & Tooling
Description	A laptop failure, a deleted local database or unpushed work could lose days of effort.
Cause	Work kept only on local machines.
Consequence	Rework and delay.
Likelihood x Impact	2 x 4 = 8 (Medium)
Early-warning indicators	A member has local changes not pushed for more than 2 days.
Mitigation (preventive actions)	Push the branch at least daily. The database is reproducible from seed data. Documents are kept in the repository (docs folder). No real data exists.
Contingency plan (if it happens)	Restore from the remote repository; regenerate the database with the dev profile.
Risk owner	Whole team
Residual risk (after mitigation)	1 x 3 = 3 (Low)
Status	Open
Related requirements	Spec. Section 9.3

R-15 | Merge conflicts and a broken main branch

Category	Process
Description	Several people edit the same files, or someone pushes broken code to a shared branch.
Cause	Beginners; shared files such as templates and services.
Consequence	Build failures and lost time.
Likelihood x Impact	4 x 3 = 12 (High)
Early-warning indicators	The build on dev or main is red; frequent conflicts in the same file.
Mitigation (preventive actions)	No direct pushes to main or dev. Short-lived branches and small pull requests. Pull from dev before starting and before opening a pull request. At least one reviewer. Run the tests before pushing.
Contingency plan (if it happens)	Revert the offending merge, fix on a branch, and re-merge.
Risk owner	Tech Lead

Residual risk (after mitigation)	2 x 2 = 4 (Low)
Status	Open
Related requirements	Spec. Section 9.3

R-16 | Low code quality or low test coverage	
Category	Quality & Testing
Description	Code can pass the demo but be hard to maintain, and some rules may have no tests.
Cause	Time pressure.
Consequence	Hidden defects; weak testing evidence for the instructor.
Likelihood x Impact	3 x 3 = 9 (Medium)
Early-warning indicators	Coverage report below target; Must requirement without a test case.
Mitigation (preventive actions)	Definition of Done (Spec. Section 8.5). Traceability table. Coverage target in the KPIs. SonarLint or SpotBugs. Code review.
Contingency plan (if it happens)	Reserve week 6 for testing and fixing; add missing tests for the highest-risk rules first.
Risk owner	QA Lead
Residual risk (after mitigation)	2 x 3 = 6 (Medium)
Status	Open
Related requirements	Spec. Sections 8.4 and 8.5; KPIs

R-17 | Limited availability (exams, other courses and training)	
Category	People & Skills
Description	Team members are final-year students with other courses and trainings, so weekly time varies.
Cause	Competing commitments.
Consequence	Uneven progress and missed milestones.
Likelihood x Impact	4 x 4 = 16 (High)
Early-warning indicators	A member reports less than half their planned hours; missed weekly meeting twice.
Mitigation (preventive actions)	Plan capacity every week. Keep tasks small (about 1 to 2 days). Use week 8 as a buffer. Share the availability calendar early (exam dates).
Contingency plan (if it happens)	Redistribute tasks and descope according to the agreed order.
Risk owner	Whole team
Residual risk (after mitigation)	3 x 3 = 9 (Medium)
Status	Open
Related requirements	Spec. Section 9.1

R-18 | Unclear ownership or poor communication	
Category	People & Skills
Description	Two people do the same task, or nobody does it, or decisions are lost in chat.
Cause	Five people, informal communication.
Consequence	Duplicated or missing work.
Likelihood x Impact	3 x 3 = 9 (Medium)
Early-warning indicators	A task without an owner for more than 2 days; the same question asked twice.
Mitigation (preventive actions)	One owner and one reviewer per task (Task Assignment table). Jira board is the source of truth. Weekly meeting with notes. Decisions recorded in the document.
Contingency plan (if it happens)	The team assigns an owner on the spot and records it in Jira.
Risk owner	Whole team
Residual risk (after mitigation)	2 x 2 = 4 (Low)
Status	Open
Related requirements	Spec. Section 9.2

R-19 | Demo failure on presentation day	
Category	Delivery
Description	The environment may fail at the presentation: wrong database state, port in use, laptop issue, a bug in a live path.
Cause	Live demonstrations are fragile.
Consequence	A good project looks broken.
Likelihood x Impact	3 x 5 = 15 (High)
Early-warning indicators	Any failure during rehearsals.
Mitigation (preventive actions)	Local demo with no internet. Two rehearsals in week 7. A reset script and fresh seed data before the demo. The project installed on a second laptop. A recorded video of the demo as a backup. A short checklist of the demo path.
Contingency plan (if it happens)	Switch to the second laptop or the recorded video; present the test reports as evidence.
Risk owner	Tech Lead
Residual risk (after mitigation)	2 x 3 = 6 (Medium)
Status	Open
Related requirements	Spec. Section 9.1 (weeks 7 and 8)

R-20 | Instructor expectations not covered (named deliverables)	
Category	Delivery
Description	The instructor asked for specific items (Project Proposal, Project Plan, Task Assignment and Roles, Risk Assessment and Mitigation Plan, KPIs) and for specific tools.

Cause	Requirements for documents came after the technical design.
Consequence	Marks lost for missing items.
Likelihood x Impact	3 x 4 = 12 (High)
Early-warning indicators	The instructor asks for an item that is not in the document set.
Mitigation (preventive actions)	All named items are now in the requirements document (Spec. Sections 0 and 9) and in this separate plan. Deliverables traceability table (Spec. Section 1.4). Check the list with the instructor before the final week.
Contingency plan (if it happens)	Add the missing item within 48 hours.
Risk owner	QA Lead
Residual risk (after mitigation)	1 x 3 = 3 (Low)
Status	Mitigated - the items are in the document set
Related requirements	Spec. Section 1.4

R-21 | Estimation errors

Category	Schedule & Scope
Description	Tasks such as transfer with fees, scheduled jobs and Selenium suites may take longer than planned.
Cause	New technology; no historical data.
Consequence	Late features and compressed testing.
Likelihood x Impact	4 x 3 = 12 (High)
Early-warning indicators	A task takes more than twice its estimate.
Mitigation (preventive actions)	Estimate in days, not hours; add 30% buffer for new tools. Do the riskiest work early (for example the SQLite spike in week 1). Track planned versus actual in Jira. Re-plan every week.
Contingency plan (if it happens)	Move the lowest-priority item out of the week and tell the team.
Risk owner	Tech Lead
Residual risk (after mitigation)	3 x 2 = 6 (Medium)
Status	Open
Related requirements	Spec. Section 9.1

R-22 | Tool access and plan limits (GitHub organisation, Jira)

Category	Environment & Tooling
Description	Some features (branch protection on private repositories, Jira automation) may be limited on free plans or need admin rights.
Cause	Free plans; role permissions.
Consequence	Rules cannot be enforced by the tools.
Likelihood x Impact	2 x 2 = 4 (Low)

Early-warning indicators	A needed setting is unavailable or greyed out.
Mitigation (preventive actions)	Set up the organisation, repository and Jira in week 1. Give admin rights to two team members chosen by the team. If protection is unavailable, enforce the rules by team agreement and review.
Contingency plan (if it happens)	Use a public repository or a manual review checklist.
Risk owner	Tech Lead
Residual risk (after mitigation)	1 x 2 = 2 (Low)
Status	Open
Related requirements	Spec. Section 9.3

R-23 | Market figures change (limits, fees, interest rates)	
Category	External
Description	The real figures used for limits, fees and rates can change before the demo.
Cause	External sources (payment network, central bank, banks).
Consequence	Numbers in the documents look outdated.
Likelihood x Impact	2 x 2 = 4 (Low)
Early-warning indicators	News about a change in limits, fees or policy rates.
Mitigation (preventive actions)	All numbers live in application.yml. Re-check the sources in the final week. Record the check date in the document.
Contingency plan (if it happens)	Change the configuration and the affected test data and documents.
Risk owner	QA Lead
Residual risk (after mitigation)	1 x 2 = 2 (Low)
Status	Open
Related requirements	Spec. Section 4

R-24 | Code that the team does not fully understand	
Category	Quality & Testing
Description	Some code may be generated by tools, taken from examples, or written by someone else. If members cannot explain it, they cannot maintain it, test it well, or answer questions at the presentation.
Cause	Fast progress; beginners; code written by others.
Consequence	Hidden defects; weak answers at the presentation; academic integrity questions.
Likelihood x Impact	3 x 4 = 12 (High)
Early-warning indicators	A member cannot explain what a class or test does; a bug stays unresolved because nobody understands the code.
Mitigation (preventive actions)	Every member walks through their own area and explains it to the team. All code goes through review by a person who understands it. Members write tests for the code they own. The team notes where code came from (own work, examples, tools). Each member prepares to answer questions about their part.

Contingency plan (if it happens)	Schedule extra walkthrough sessions and simplify the code that nobody can explain.
Risk owner	Tech Lead
Residual risk (after mitigation)	2 x 3 = 6 (Medium)
Status	Open
Related requirements	Spec. Section 9.2; NFR-08

8. Contingency Plans and Descoping Order

8.1 Plan B scenarios

Scenario	Early signal	Fallback	Decided by
SQLite proves unreliable	Locking errors, balance mismatches, a failing concurrency test	Switch to H2 or MySQL by configuration; re-run all tests. Decide before week 4.	The team
A key member is unavailable for more than 3 days	Reviews waiting more than 48 hours	Backup reviewer for non-security changes; freeze new features; stabilise and test.	The team
A Must feature will not finish	Open Must items at the start of week 5	Descope Should and Could items first (8.2). If still short, demonstrate what works with test evidence and document the limitation; inform the instructor.	The team
UI automation unstable	Same test passes and fails	Quarantine flaky tests; keep core flows; rely on API and manual tests for the rest.	The team
A team member is absent for a long time	Missed meetings, no commits	Redistribute tasks by priority; reduce the admin-pages scope first.	The team
Demo laptop or environment fails	Failure in a rehearsal	Second laptop with the project installed; recorded demo video; test reports as evidence.	The team
Serious dependency vulnerability	Scanner alert	Upgrade or replace the library; if not possible, document as a known limitation.	The team
Requirements change late	Instructor request	Impact analysis within 24 hours; update the requirement and tests; adjust the plan.	The team

8.2 Descoping order (what to cut first, if time runs out)

Must items are never cut without a decision by the team and a note to the instructor. If cuts are needed, apply this order from the top:

#	Cut	Requirement IDs
1	Rate limit on money endpoints; JWT option	SEC-09 (Could)
2	Transfer review step wording and extra UI polish	TXN-09 (UI part)
3	CSV export of statements	STM-03

#	Cut	Requirement IDs
4	Audit-log viewing, manual interest trigger, account search, richest customer	ADM-03, ADM-04, ADM-05, ADM-06
5	Statement filters	STM-02
6	Idempotency key	TXN-08
7	Scheduled jobs (keep calculations tested but run them manually)	JOB-01, JOB-02
8	Login lockout and session timeout (only after the basic security is verified)	AUTH-06, AUTH-07

Protected items (never cut): AUTH-01 to AUTH-05 and AUTH-08, CUS-01 to CUS-03, ACC-01 to ACC-05, TXN-01 to TXN-07, STM-01, ADM-01, ADM-02, ADM-07, and all security requirements SEC-01 to SEC-04. The test evidence (test plan, automated suites, Jira reports) is also protected.

9. Monitoring, Control and Escalation

9.1 Review cadence

Activity	When	Details
Risk review	Weekly, 15 minutes inside the team meeting	Review the top risks, update scores and status, check warning signs, add new risks. The Risk Coordinator records the result in the review log (Section 11).
Warning-sign check	Continuously	Anyone who sees a warning sign posts it in the team chat and tells the risk owner.
Milestone review	End of weeks 1, 4, 6 and 8	Full re-scoring of all risks, close risks that are over, update the descoping decision.
Jira	Weekly	Mitigation actions are Jira items with an owner and a date; the label 'risk' links them to the risk ID.

9.2 Escalation rules

Situation	Action
A risk becomes Critical	Same day: tell the team. Agree the response within 24 hours. Tell the instructor if a deliverable or the schedule is threatened.
A High risk has no mitigation owner or date	The Risk Coordinator assigns one at the next meeting.
A mitigation action is late by more than one week	Raise it in the weekly review; the team decides to re-plan or cut scope.
A contingency plan is activated	Record it in the review log, inform the team, update the documents.

9.3 Risk KPIs

KPI	Target	How measured
Open Critical risks	0 at all times	Count in the register
Open High risks (residual)	0 by the end of week 4	Count of residual High in the register
Mitigation actions completed on time	85% or more	Done on time / due, from Jira
Risks without an owner	0 once owners are assigned (week 1)	Register check
Weekly risk reviews held	100% of weeks	Review log
Trend of the average residual score	Decreasing or stable	Average of residual scores each milestone

10. Assumptions, Dependencies and Constraints

Assumptions

- The team has five members with the roles in the requirements document and works about 8 weeks.
- All tools used are free; the demo is local and uses fictional data.
- The instructor reviews the deliverables listed in the brief and may ask for changes.

Dependencies

- Availability of GitHub, Jira and a working laptop for each member.
- Decisions of the instructor about open questions (for example database and tools).
- External figures (limits, fees, rates) used as configuration values.

Constraints

- Fixed deadline; no budget; limited experience in the team.
- Spring Boot 3.5 has no free updates after June 2026 (risk R-10).

11. Risk Review Log and Approval

Date	Review	Result	By
15 October 2026	Initial assessment	24 risks identified and scored. Inherent: 13 High, 9 Medium, 2 Low. Residual: 13 Medium, 11 Low. Owners are roles defined in the Requirements, Section 9.2.	Project team

Role	Name	Date and signature
Prepared by (Risk Coordinator)		
Reviewed by (Tech Lead)		

Role	Name	Date and signature
Reviewed by (Instructor)		

Appendix A. Glossary

Term	Meaning
Inherent risk	The risk before any mitigation action.
Residual risk	The risk that remains after the mitigation actions.
Mitigation	Actions taken in advance to reduce the likelihood or the impact.
Contingency plan	What the team does if the risk happens anyway (Plan B).
Early-warning indicator	A signal that a risk is becoming real.
Descoping	Removing lower-priority features to protect the schedule.
MoSCoW	Must, Should, Could priorities used in the requirements.
IDOR	Insecure Direct Object Reference: a user reaches another user's data by changing an identifier.
Spike	A short experiment done early to remove a technical unknown.